Principles of Security

Confidentiality - The principle of keeping data secret and protecting it from being viewed by unauthorized individuals.

Integrity - The principle of ensuring data is accurate, complete, and has not been improperly modified or destroyed.

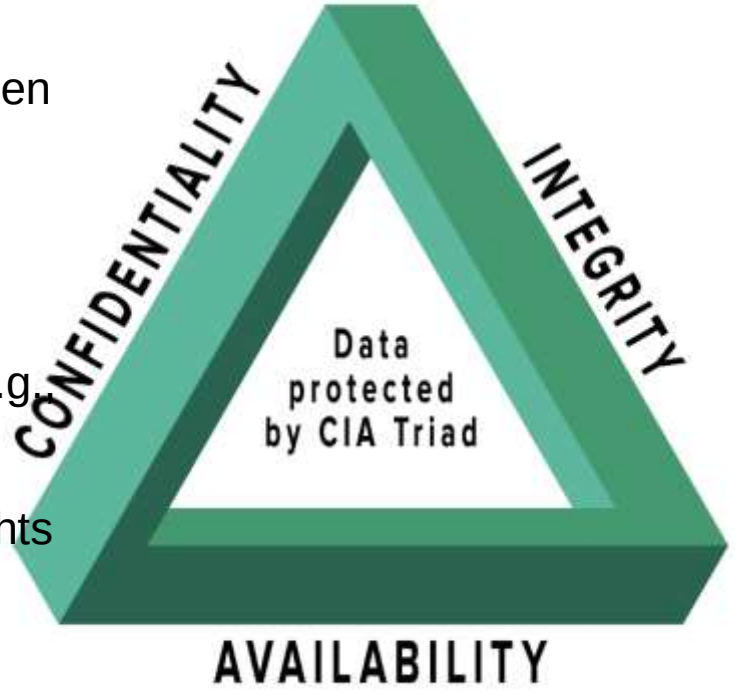
Availability - The principle of ensuring that authorized users can access systems and data whenever they are needed.

Authentication - The process of verifying the identity of a user or system (e.g., checking a password or biometric).

Authorization - The process of granting specific permissions or access rights to an authenticated user for a resource.

Accountability / Non-repudiation - Ensuring that all actions taken within a system can be traced back to a specific entity, making denial impossible.

Privacy - The right of individuals to control how their personal and sensitive information is collected, used, and shared.



Access Control Models : These are different rule sets for how Authorization (what you're allowed to do) is enforced in a system

DAC (Discretionary Access Control) - The owner of a resource (like a file) gets to decide who can access it and what permissions they have.
MAC (Mandatory Access Control) - Access is based on a fixed security classification level (e.g., Top Secret, Confidential) assigned by a central authority.
RBAC (Role-Based Access Control) - Access permissions are grouped by the job function or role of the user (e.g., "Accountant," "HR Manager"), not the individual.
ABAC (Attribute-Based Access Control) - Access is granted based on a combination of many characteristics (attributes) about the user, the resource, and the environment (e.g., "Allow access if user is HR and the time is 9 am to 5 pm").
Zero Trust - A security model that assumes no user or device, inside or outside the network, is trusted by default; every access attempt must be verified.



Security Domains

Information Security Management - The high-level process of developing, implementing, and maintaining an organization's overall security strategy and framework.

Network Security - The measures taken to protect the organization's network infrastructure (wires, routers, Wi-Fi) from unauthorized access or misuse.

Application Security - The security controls built into software applications throughout their development to protect them from code-level vulnerabilities.

Cloud Security - The practices used to secure data, applications, and infrastructure hosted with third-party cloud providers (e.g., AWS, Azure).

Database Security - The defensive measures focused on protecting the structured data stores (databases) from unauthorized access, corruption, or theft.

Endpoint Security - The practice of securing end-user devices, such as laptops, desktops, and mobile phones, that connect to the network.



Physical Security - The protection of an organization's tangible assets (buildings, hardware, people) from real-world threats like theft or damage.

IoT Security - The practices dedicated to securing small, often resource-constrained Internet of Things (IoT) devices like smart cameras and sensors.

Mobile Security - The security measures and management policies specifically aimed at protecting data on smartphones and tablets.

Cybersecurity Operations - The daily operational activities (monitoring, detection, and response) performed to maintain the ongoing security of systems.

Policies, Standards & Frameworks

Security Policies & Procedures - Policies are high-level rules defining what must be done; Procedures are the detailed, step-by-step instructions for how to do it.

Risk Management & Assessment **-** The structured process of identifying, analyzing, and evaluating risks, and then deciding on appropriate methods to mitigate or manage them.

Security Controls - Mechanisms (technical or administrative) implemented to prevent, detect, or correct security violations and reduce risk.

Compliance & Regulatory Requirements - Adherence to mandatory laws, regulations, or industry standards (like GDPR, HIPAA, or PCI-DSS) governing data security.

Incident Response & Recovery - The organized plan and process for identifying, managing, and resolving a security breach or attack to minimize damage.

Business Continuity & Disaster Recovery (BCDR) - BC keeps core business functions running during a crisis; DR focuses on fully restoring IT systems after a major disaster.

Security Practices

Vulnerability Assessment - The practice of scanning systems to find weaknesses or flaws (vulnerabilities) that a threat could exploit.

Penetration Testing (Pen Test) - A method where authorized security experts simulate a real cyberattack against a system to find and exploit weaknesses.

Security Auditing & Monitoring - The continuous practice of reviewing logs, activity, and configurations to ensure compliance with policies and detect suspicious events.

Patch Management - The systematic process of acquiring, testing, and applying software updates (patches) to fix security vulnerabilities.

Intrusion Detection & Prevention (IDS/IPS) - IDS is a system that alerts when a potential attack is happening; IPS is a system that automatically blocks the attack in real-time.

Security Awareness Training The ongoing educational process used to teach employees about security risks, policies, and how to behave safely to protect company assets.